

5.1 MFA Security Policies

5.1 MFA Security Policies

5.1.1 Overview

The MFA Security Policies at FinSecure Pvt. Ltd. define the rules, controls, and enforcement mechanisms governing the use of multi-factor authentication across all enterprise systems. These policies are designed to ensure consistent security practices, reduce the risk of unauthorized access, and align with industry standards.

5.1.2 Policy Objectives

- Enforce strong authentication across all systems
 - Protect against credential-based attacks (phishing, brute-force, credential stuffing)
 - Standardize authentication practices across the organization
 - Ensure compliance with regulatory and security frameworks
-

5.1.3 MFA Enforcement Policy

- MFA is **mandatory for all users** accessing:
 - Microsoft 365 services
 - VPN and remote access systems
 - Internal business applications
 - MFA must be enforced:
 - During initial login
 - During high-risk access attempts
 - When accessing sensitive data or systems
-

5.1.4 Authentication Methods Policy

Primary Method

- Authenticator apps (TOTP / push-based authentication)
-

Secondary / Fallback Methods

- SMS OTP (restricted use)
 - Email OTP (restricted use)
-

High-Security Methods

- Hardware tokens (FIDO2) for:
 - Admin accounts
 - Privileged users
-

Device-Based Authentication

- Biometrics allowed only on:
 - Managed and trusted devices
-

5.1.5 Privileged Access Policy

- All privileged accounts must:
 - Use MFA at all times
 - Prefer hardware tokens where feasible
 - Additional controls:
 - No fallback to SMS/email for admin access
 - Strict monitoring of privileged logins
-

5.1.6 Conditional Access Policy

MFA enforcement will be dynamically applied based on risk signals:

- New or unrecognized device
 - Login from unusual location
 - High-risk user behavior
 - Access to sensitive systems
-

5.1.7 Session Management Policy

- Session timeout enforced after inactivity
 - Re-authentication required for:
 - Sensitive actions
 - Privileged operations
 - Token/session lifetime must be limited
-

5.1.8 Account Lockout Policy

- Maximum failed attempts: 3–5
 - Temporary account lockout enforced
 - Escalation for repeated failures
-

5.1.9 Recovery & Reset Policy

- Users must have at least one backup MFA method
 - MFA reset requires:
 - Identity verification
 - IT/admin approval
 - Temporary bypass allowed only under controlled conditions
-

5.1.10 Logging & Audit Policy

- All authentication attempts must be logged:
 - Successful logins
 - Failed logins
 - MFA challenges
 - Logs must include:
 - Timestamp
 - User identity
 - Device/location details
-

5.1.11 Policy Enforcement

- Policies enforced centrally via:
 - Microsoft Entra ID
 - Conditional Access
 - Non-compliant users:
 - Denied access
 - Required to complete MFA enrollment
-

5.1.12 Summary

The MFA Security Policies establish a strong and consistent authentication framework across FinSecure, ensuring that all access to enterprise systems is protected by robust, risk-aware, and centrally enforced security controls.

5.2 Compliance Mapping (GDPR, HIPAA, etc.)

5.2 Compliance Mapping (GDPR, HIPAA, etc.)

5.2.1 Overview

FinSecure Pvt. Ltd., as a financial services organization handling sensitive customer and employee data, must ensure that its authentication and access control mechanisms align with relevant regulatory and industry standards.

The implementation of Multi-Factor Authentication (MFA) directly supports compliance requirements by strengthening identity verification, protecting sensitive data, and enabling secure access control.

This section maps the MFA implementation to key regulatory frameworks:

- GDPR (General Data Protection Regulation)
 - HIPAA (Health Insurance Portability and Accountability Act)
 - NIST Cybersecurity Framework (CSF)
-

5.2.2 GDPR Compliance Mapping

Relevant Requirements

- Protection of personal data
- Prevention of unauthorized access
- Implementation of appropriate technical and organizational measures\

The primary regulatory basis is **Article 32 of the GDPR**, which requires organizations to implement "appropriate technical and organisational measures" to ensure a level of security appropriate to the risk. Specifically, Article 32(1)(a) references "pseudonymisation and encryption of personal data" and Article 32(1)(b) requires "the ability to ensure the ongoing confidentiality, integrity, availability and resilience of processing systems." MFA directly satisfies Article 32 by ensuring that access to systems holding personal data of FinSecure's customers requires more than a single compromised credential. The absence of MFA would represent a failure to implement appropriate technical measures, exposing the organization to enforcement action under Article 83 GDPR, which carries fines of up to €20 million or 4% of global annual turnover.

MFA Alignment

- MFA ensures **strong user authentication**, reducing risk of data breaches
 - Conditional access policies prevent unauthorized access from risky locations
 - Logging and monitoring support **auditability and breach investigation**
-

Key Controls Implemented

- Mandatory MFA for all users
 - Secure session management
 - Centralized identity management
 - Access logging and monitoring
-

5.2.3 HIPAA Compliance Mapping

(Applicable where health-related data may be processed or integrated)

Relevant Requirements

- Access control mechanisms
 - Unique user identification
 - Audit controls
 - Transmission security
-

MFA Alignment

- MFA enforces **unique user verification**
 - Strengthens access control for sensitive data systems
 - Ensures secure authentication before granting access
-

Key Controls Implemented

- MFA for all system access
- Role-based access control (RBAC)
- Audit logs for all authentication events
- Secure communication channels (HTTPS, VPN)

The applicable regulatory standard is the **HIPAA Security Rule, 45 CFR §164.312(d)**, which mandates that covered entities "implement procedures to verify that a person or entity seeking access to electronic protected health information is the one claimed." MFA directly implements this requirement by adding a second verification factor beyond password. Additionally, **§164.312(a)(2)(i)** requires unique user identification — MFA enforcement combined with individual account assignment (as recommended in section 3.3.4) ensures each access event is attributable to a specific individual. **§164.312(b)** requires audit controls — the centralized logging setup in section 5.3 satisfies this by capturing every authentication event with user identity, timestamp, device, and location.

5.2.4 NIST Cybersecurity Framework (CSF) Alignment

Relevant Functions

1. Identify

- User identity management via Active Directory and Entra ID

2. Protect

- MFA implementation across all systems
- Conditional access policies
- Strong authentication mechanisms

3. Detect

- Monitoring of authentication logs
- Detection of suspicious login attempts

4. Respond

- Incident response plan for authentication-related incidents
- MFA reset and recovery procedures

5. Recover

- Backup authentication methods
- Account recovery mechanisms

The applicable NIST publication is **NIST SP 800-63B (Digital Identity Guidelines — Authentication and Lifecycle Management)**, which defines three Authentication Assurance Levels (AAL). FinSecure's current password-only authentication meets only **AAL1** — the lowest level, offering minimal assurance. The proposed MFA implementation using authenticator apps achieves **AAL2**, which NIST defines as requiring "proof of possession and control of two distinct authentication factors." FIDO2 hardware tokens for privileged accounts achieve **AAL3** — the highest level, requiring a hardware cryptographic authenticator. NIST SP 800-63B explicitly states that AAL2 is the minimum recommended level for systems handling sensitive data, making the proposed MFA implementation not just good practice but aligned with federal security guidance.

5.2.5 Additional Security Best Practices Alignment

- **Least Privilege Access**
 - **Zero Trust Principles** (verify every access attempt)
 - **Phishing-resistant authentication (FIDO2)**
 - **Secure remote access via VPN with MFA**
-

5.2.6 RBI IT Framework Compliance

As a financial services organization operating in India, FinSecure is subject to the **Reserve Bank of India's IT Framework for the NBFC Sector (2017)** and the broader **RBI Cyber Security Framework**. Key requirements relevant to MFA include:

- **Multi-factor authentication** is explicitly mandated for all internet-facing applications and remote access systems under the RBI Cyber Security Framework
- **Access control** requirements specify that privileged access must be strictly controlled and individually attributed — satisfied by the FIDO2 hardware token policy for IT administrators
- **Audit log retention** under RBI guidelines requires critical authentication logs to be retained for a **minimum of 3 years** — FinSecure's log retention policy in section 5.3.7 should be updated to reflect this requirement rather than the 90-day minimum stated

Compliance with RBI guidelines is not optional — non-compliance can result in regulatory action from the RBI against the organization's operating licence.

5.2.6 Compliance Benefits for FinSecure

- Reduced risk of regulatory penalties
 - Improved customer trust and data protection
 - Stronger audit readiness
 - Enhanced security posture aligned with global standards
-

5.2.7 Summary

The MFA implementation at FinSecure aligns closely with major regulatory frameworks such as GDPR, HIPAA, and NIST CSF. By enforcing strong authentication, centralized identity management, and continuous monitoring, the organization ensures compliance with industry standards while significantly enhancing its overall security posture.

5.3 Monitoring Setup (SIEM, Logs)

5.3 Monitoring Setup (SIEM, Logs)

5.3.1 Overview

Monitoring is a critical component of FinSecure Pvt. Ltd.'s MFA implementation, enabling continuous visibility into authentication activities and early detection of suspicious behavior. A centralized monitoring approach is implemented using **log collection, analysis, and Security Information and Event Management (SIEM)** tools to track authentication events across all systems.

5.3.2 Monitoring Architecture

The monitoring setup includes:

- **Log Sources:**
 - Microsoft Entra ID (Azure AD)
 - Active Directory
 - VPN (NPS/RADIUS logs)
 - Application access logs
 - **Log Aggregation:**
 - Centralized log collection platform
 - **SIEM System:**
 - Microsoft Sentinel (recommended) or equivalent
-

5.3.3 Log Collection Setup

1. Identity Provider Logs (Entra ID)

- Enable logging for:
 - Sign-in activity
 - MFA challenges
 - Conditional access events
 - Capture:
 - User identity
 - Device information
 - Location (IP/geolocation)
 - Authentication method used
-

2. Active Directory Logs

- Enable audit logging on domain controllers:
 - Login attempts
 - Account lockouts
 - Password changes
-

3. VPN Logs (NPS / RADIUS)

- Capture:
 - Connection attempts
 - Authentication success/failure
 - MFA trigger events
-

4. Application Logs

- Monitor:
 - SSO login events
 - Token usage
 - Session creation and termination
-

5.3.4 SIEM Integration

- Integrate all log sources into SIEM (e.g., Microsoft Sentinel)
 - Configure data connectors for:
 - Entra ID
 - Active Directory
 - VPN systems
 - Normalize logs for:
 - Consistent analysis
 - Correlation across systems
-

5.3.5 Alerting & Monitoring Rules

Set up alerts for:

- Multiple failed login attempts
 - Login from unusual geographic locations
 - Access from unrecognized devices
 - Repeated MFA failures or push denials
 - Privileged account access
-

5.3.6 Dashboard & Visibility

Create dashboards for:

- Login activity trends
 - MFA usage statistics
 - Failed vs successful authentication attempts
 - High-risk login events
-

5.3.7 Log Retention Policy

- Retain authentication logs for:
 - Minimum 90 days (operational); minimum 3 years for critical authentication logs in compliance with RBI IT Framework guidelines.
 - Extended retention for compliance (as required)
 - Ensure:
 - Secure storage
 - Access control for logs
-

5.3.8 Security Considerations

- Protect logs from unauthorized access
 - Ensure logs are tamper-resistant
 - Encrypt log data in transit and at rest
-

5.3.9 Recommended Setup at FinSecure

- Use **Microsoft Sentinel** for SIEM integration
 - Enable logging across all identity and access systems
 - Monitor authentication events in real-time
 - Regularly review logs and alerts
-

5.3.10 Summary

The monitoring setup at FinSecure ensures comprehensive visibility into authentication activities across all systems. By integrating logs into a centralized SIEM platform and configuring real-time alerts, the organization can quickly detect and respond to potential security threats.

5.4 Detection Use Cases

5.4 Detection Use Cases

5.4.1 Overview

Detection use cases define specific scenarios where suspicious or malicious authentication activity can be identified using logs and monitoring systems.

At FinSecure Pvt. Ltd., these use cases are implemented within the SIEM platform to detect threats in real-time and trigger alerts for investigation and response.

5.4.2 Key Detection Categories

- Credential-based attacks
 - Unauthorized access attempts
 - MFA abuse and bypass attempts
 - Privileged account misuse
-

5.4.3 Detection Use Cases

1. Multiple Failed Login Attempts (Brute-force Detection)

Description:

Detect repeated failed login attempts for a user account within a short time frame.

Indicators:

- Multiple failed password attempts
- Account lockout triggered

Action:

- Trigger alert
 - Temporarily lock account
 - Notify IT/security team
-

2. Impossible Travel Detection

Description:

Detects logins from geographically distant locations within a short time span.

Indicators:

- Login from Mumbai followed by login from another country within minutes

Action:

- Trigger high-risk alert
 - Require re-authentication with MFA
 - Investigate user activity
-

3. Login from Unrecognized Device

Description:

Detect access attempts from devices not previously associated with the user.

Indicators:

- New device fingerprint
- Unknown browser or OS

Action:

- Trigger MFA challenge
 - Flag for monitoring
-

4. Excessive MFA Push Requests (MFA Fatigue Attack)

Description:

Detect repeated MFA push notifications sent to a user within a short period.

Indicators:

- Multiple MFA prompts without successful login
- User denial of repeated requests

Action:

- Block authentication attempt
 - Alert security team
 - Educate user
-

5. Privileged Account Login Outside Normal Hours

Description:

Detect admin or privileged account access outside defined working hours.

Indicators:

- Login during late night or unusual hours
- Access to sensitive systems

Action:

- Trigger alert
 - Require additional verification
 - Review activity logs
-

6. Repeated MFA Failures

Description:

Detect multiple failed MFA attempts for a user account.

Indicators:

- Incorrect OTP entries
- MFA challenge failures

Action:

- Lock account temporarily
 - Alert IT/security team
-

7. VPN Login Anomalies

Description:

Detect unusual VPN access patterns.

Indicators:

- Login from new location
- Multiple failed VPN attempts
- Access from non-compliant device

Action:

- Block access
 - Trigger MFA re-authentication
 - Investigate connection logs
-

8. Suspicious Token Usage (SSO Abuse)

Description:

Detect abnormal use of authentication tokens.

Indicators:

- Token reuse from different IP addresses
- Unusual session behavior

Action:

- Invalidate session
 - Force re-authentication
 - Investigate potential compromise
-

5.4.4 Implementation in SIEM

- Configure detection rules using:
 - Log correlation
 - Threshold-based alerts
 - Behavioral analytics
 - Use built-in analytics (e.g., Microsoft Sentinel) where available
-

5.4.5 Severity Classification

Severity	Example Use Cases
High	Impossible travel, privileged account misuse
Medium	Repeated MFA failures, VPN anomalies
Low	New device login, minor login failures

5.4.6 Response Integration

- Alerts automatically trigger:
 - Incident creation
 - Notification to IT/security team
 - Automated response (where configured)
-

5.4.7 Summary

Detection use cases enable FinSecure to proactively identify and respond to authentication-related threats. By defining clear scenarios and integrating them with SIEM tools, the organization strengthens its ability to detect anomalies and prevent potential security breaches.

5.5 Incident Response Plan

5.5 Incident Response Plan

5.5.1 Overview

The Incident Response Plan (IRP) at FinSecure Pvt. Ltd. defines the structured approach for identifying, analyzing, containing, and resolving security incidents related to authentication and MFA systems.

The objective is to minimize the impact of security incidents, prevent unauthorized access, and restore normal operations as quickly as possible.

5.5.2 Incident Categories

Authentication-related incidents include:

- Compromised user credentials
 - Suspicious login activity
 - MFA bypass attempts
 - Account takeover incidents
 - Privileged account misuse
-

5.5.3 Incident Response Lifecycle

The response process follows a structured lifecycle:

1. Identification

Objective: Detect and confirm a potential security incident

Sources:

- SIEM alerts
- User reports
- Monitoring dashboards

Actions:

- Validate alert accuracy
 - Identify affected user/system
 - Classify incident severity
-

2. Containment

Objective: Limit the impact of the incident

Actions:

- Temporarily disable affected account
 - Terminate active sessions
 - Block suspicious IP addresses
 - Enforce immediate MFA re-authentication
-

3. Eradication

Objective: Remove the root cause of the incident

Actions:

- Reset user credentials
 - Reconfigure MFA settings if compromised
 - Remove unauthorized access or devices
 - Patch vulnerabilities (if applicable)
-

4. Recovery

Objective: Restore normal operations securely

Actions:

- Re-enable user access after verification
 - Re-enroll MFA if required
 - Monitor account activity post-recovery
-

5. Post-Incident Review

Objective: Improve future response and prevention

Actions:

- Document incident details
 - Analyze root cause
 - Update policies and detection rules
 - Conduct internal review
-

5.5.4 Roles & Responsibilities

Role	Responsibility
IT Team	Initial response and containment
System Administrators	Account and system remediation
Management	Decision-making for critical incidents
Users	Reporting suspicious activity

5.5.5 Severity Levels

Severity	Description	Example
High	Active breach or compromise	Account takeover
Medium	Suspicious activity	Repeated MFA failures
Low	Minor anomaly	New device login

5.5.6 Response Actions by Severity

High Severity

- Immediate account lock
 - Force password reset
 - Revoke sessions
 - Full investigation
-

Medium Severity

- Trigger additional MFA
 - Monitor activity
 - Notify user
-

Low Severity

- Log event
 - Continue monitoring
-

5.5.7 Communication Plan

- Notify:
 - Affected user
 - IT/security team
 - Management (for high severity)
 - Maintain clear communication:
 - Incident status
 - Actions taken
 - Required user steps
-

5.5.8 Tools & Systems Used

- SIEM (Microsoft Sentinel)
 - Identity logs (Entra ID)
 - VPN logs (NPS/RADIUS)
-

5.5.9 Integration with Monitoring

- Alerts from detection use cases automatically:
 - Trigger incident workflows
 - Generate tickets
 - Notify responsible teams
-

5.5.10 Summary

The Incident Response Plan ensures that FinSecure can effectively detect, contain, and resolve authentication-related security incidents. By following a structured lifecycle and clearly defined responsibilities, the organization minimizes risk and ensures rapid recovery from potential threats.

5.6 Awareness & Training Plan

5.6 Awareness & Training Plan

5.6.1 Overview

The Awareness & Training Plan at FinSecure Pvt. Ltd. is designed to educate users on secure authentication practices, proper use of Multi-Factor Authentication (MFA), and the identification of potential security threats.

Since human behavior plays a critical role in security, this plan ensures that employees understand their responsibilities and actively contribute to maintaining a secure environment.

5.6.2 Objectives

- Improve user understanding of MFA and its importance
 - Reduce risks from phishing and social engineering attacks
 - Prevent misuse of authentication systems
 - Encourage proactive reporting of suspicious activities
-

5.6.3 Target Audience

- All employees (general awareness)
 - IT team (technical training)
 - Privileged users (advanced security practices)
-

5.6.4 Training Programs

1. MFA Usage Training

- How to:
 - Set up authenticator apps
 - Use OTP and push notifications
 - Handle backup authentication methods
- Best practices:
 - Never share OTPs
 - Approve only legitimate MFA requests

2. Phishing Awareness Training

- Identify:
 - Suspicious emails
 - Fake login pages
 - Social engineering attempts
- Simulated phishing exercises (recommended)

3. Secure Authentication Practices

- Use strong passwords
- Avoid password reuse
- Protect authentication devices

4. Privileged User Training

- Additional controls for:
 - Admin accounts
 - Sensitive system access
- Emphasis on:
 - Hardware token usage
 - Monitoring responsibilities

5.6.5 Awareness Campaigns

- Periodic email reminders
- Posters or internal communications
- Short awareness videos

Key topics:

- MFA importance
 - Phishing risks
 - Safe login behavior
-

5.6.6 User Responsibilities

All users must:

- Complete MFA enrollment
 - Protect their authentication devices
 - Report suspicious activity immediately
 - Avoid approving unknown MFA requests
-

5.6.7 Reporting Mechanism

- Users can report:
 - Suspicious login attempts
 - Unexpected MFA prompts
 - Phishing emails
 - Reporting channels:
 - IT helpdesk
 - Email reporting system
-

5.6.8 Training Frequency

- Initial training during onboarding
 - Periodic refreshers (quarterly or bi-annually)
 - Targeted training after incidents
-

5.6.9 Effectiveness Measurement

- Track:
 - Training completion rates
 - Phishing simulation results
 - Number of reported incidents
 - Use feedback to improve programs
-

5.6.10 Recommended Approach at FinSecure

- Make MFA training mandatory for all employees
 - Conduct regular phishing simulations
 - Focus on practical, scenario-based learning
 - Reinforce awareness through continuous communication
-

5.6.11 Summary

The Awareness & Training Plan ensures that employees at FinSecure are equipped to use MFA securely and recognize potential threats. By combining education, continuous awareness, and user accountability, the organization strengthens its overall security posture and reduces human-related risks.